

UNIT V

E-MAIL, IP & WEB SECURITY

E-mail Security: Pretty Good Privacy-S/MIME. IPSecurity: Overview of IPsec - IP and IPv6- Authentication Header-Encapsulation Security Payload (ESP). Web Security: SSL/TLS Basic Protocol-computing the keys- client authentication- Case Study : Privacy and Security of Aadhar .

SECURITY SERVICES FOR ELECTRONIC MAIL

1. **Privacy**—the ability to keep anyone but the intended recipient from reading the message.
2. **Authentication**—reassurance to the recipient of the identity of the sender.
3. **Integrity**—reassurance to the recipient that the message has not been altered since it was transmitted by the sender.
4. **Non-repudiation**—the ability of the recipient to prove to a third party that the sender really did send the message. This feature is also sometimes called **third party authentication**. The term non-repudiation means that the sender cannot later deny sending the message.
5. **Proof of submission**—verification given to the sender that the message was handed to the mail delivery system.
6. **Proof of delivery**—verification that the recipient received the message. Postal mail has a similar feature (return receipt requested), but again it only verifies that something was delivered on a particular date to the recipient. With electronic mail it is possible to verify the contents, as we mentioned under proof of submission.
7. **Message flow confidentiality**—an extension of privacy such that Carol not only cannot know the content of the message Alice sent Bob, but cannot even determine whether Alice sent Bob a message.
8. **Anonymity**—the ability to send a message so that the recipient can't find out the identity of the sender.
9. **Containment**—the ability of the network to keep certain security levels of information from leaking out of a particular region.
10. **Audit**—the ability of the network to record events that might have some security relevance, such as that Alice sent a message to Bob on a particular date. This would be fairly straightforward to implement, but is not mentioned in any of the secure mail standards, so we don't have a section on it.
11. **Accounting**—the ability of the mail system to maintain system usage statistics. In addition to providing clues for system resource management, this information allows the mail system to charge its clients according to their usage.
12. **Self-destruct**—an option allowing a sender to specify that a message should be destroyed after delivery to the recipient. This allows Alice to send a message to Bob that Bob cannot forward or store. The mail system will decrypt and display the message, but then delete it.
13. **Message sequence integrity**—reassurance that an entire sequence of messages arrived in the order transmitted, without any loss.

PRETTY GOOD PRIVACY

PGP provides a confidentiality and authentication service that can be used for electronic mail and file storage applications. In essence, Zimmermann has done the following:

1. Selected the best available cryptographic algorithms as building blocks.
2. Integrated these algorithms into a general-purpose application that is independent of operating system and processor.
3. Made the package and its documentation, including the source code, freely available via the Internet.
4. Entered into an agreement with a company to provide a fully compatible, low-cost commercial version of PGP.

PGP has grown explosively and is now widely used. A number of reasons can be cited for this growth:

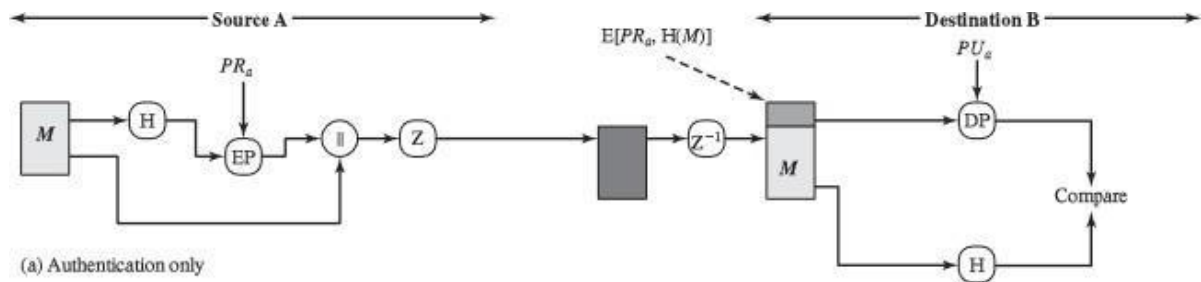
1. It is available free worldwide in versions that run on a variety of platforms.
2. It is based on algorithms that are extremely secure.
3. It has a wide range of applicability.
4. It was not developed by, nor is it controlled by, any governmental or standards organization
5. PGP is now on an Internet standards track.

Operational Description

- (i) Authentication
- (ii) Confidentiality
- (iii) Compression
- (iv) E-Mail compatibility
- (v) Segmentation

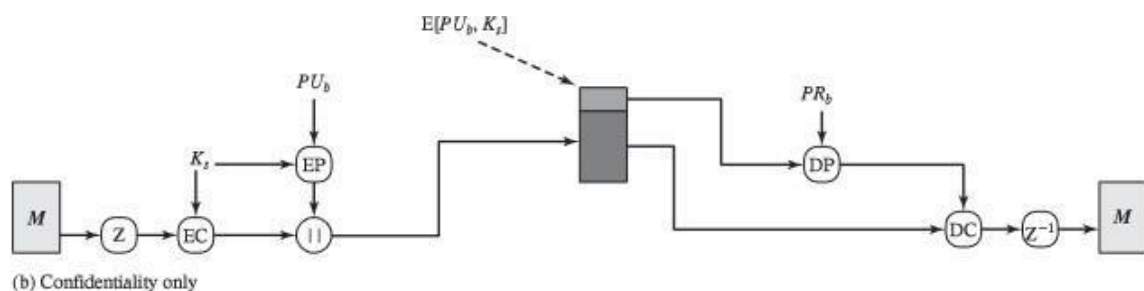
(i) Authentication

- The sender creates a message.
- SHA-1 is used to generate a 160-bit hash code of the message.
- The hash code is encrypted with RSA using the sender's private key, and the result is prepended to the message.
- The receiver uses RSA with the sender's public key to decrypt and recover the hash code.
- The receiver generates a new hash code for the message and compares it with the decrypted hash code. If the two match, the message is accepted as authentic.



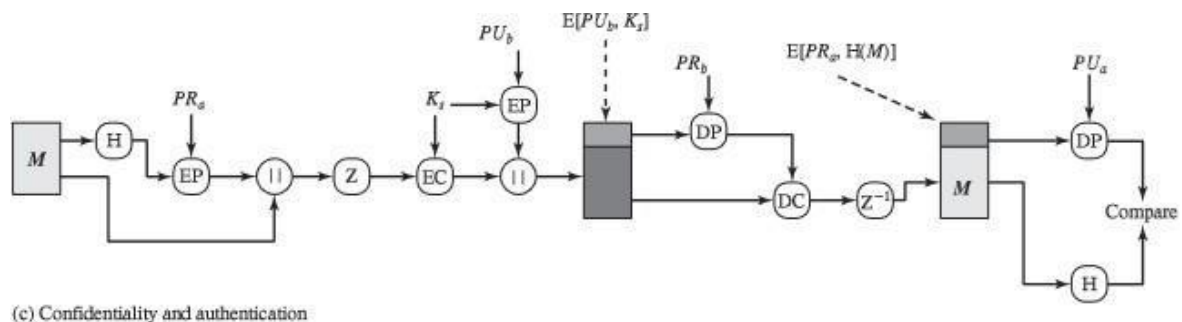
(ii) Confidentiality

- The sender generates a message and a random 128-bit number to be used as a session key for this message only.
- The message is encrypted, using CAST-128 (or IDEA or 3DES) with the session key.
- The session key is encrypted with RSA, using the recipient's public key, and is prepended to the message.
- The receiver uses RSA with its private key to decrypt and recover the session key.
- The session key is used to decrypt the message.



(iii) Confidentiality and Authentication

When both services are used, the sender first signs the message with its own private key, then encrypts the message with a session key, and then encrypts the session key with the recipient's public key.

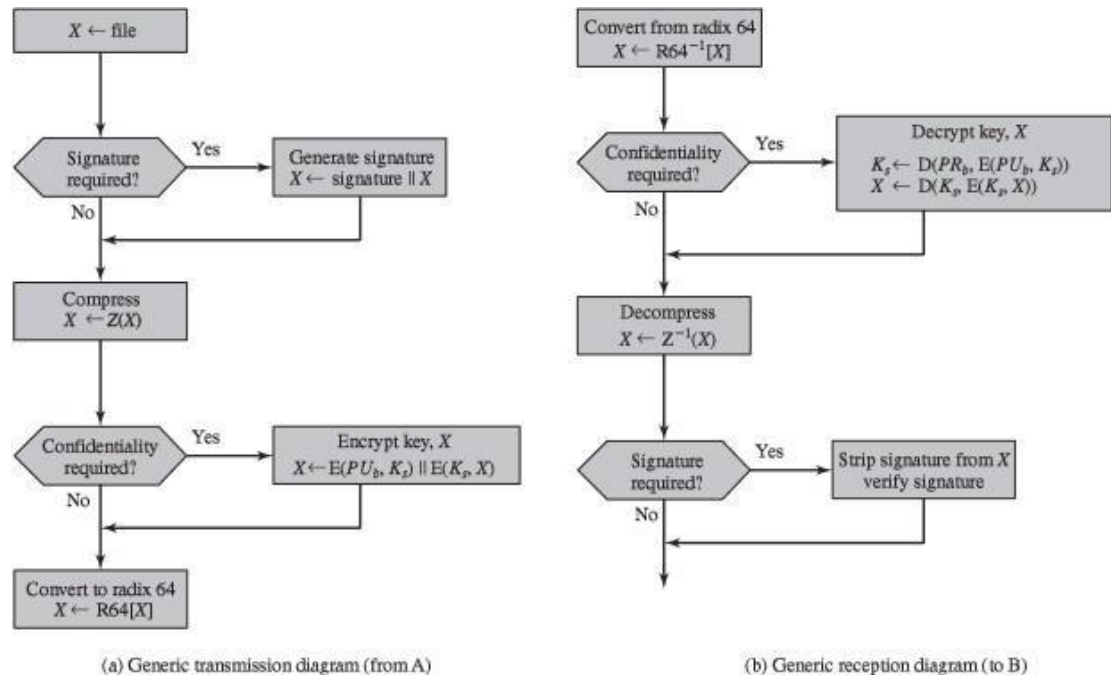


(iv) Compression

PGP compresses the message after applying the signature but before encryption. The compression algorithm is indicated by Z for compression and Z^{-1} for decompression. The signature is generated before compression for two reasons:

- It is preferable to sign an uncompressed message so that one can store only the uncompressed message together with the signature for future verification.

- b) Even if one were willing to generate dynamically a recompressed message for verification, PGP's compression algorithm presents a difficulty. The algorithm is not deterministic.
- c) Message encryption is applied after compression to strengthen cryptographic security. Because the compressed message has less redundancy than the original plaintext, cryptanalysis is more difficult.



Transmission and Reception of PGP Messages

(v) E-mail Compatibility

When PGP is used, at least part of the block to be transmitted is encrypted. PGP provides the service of converting the raw 8-bit binary stream to a stream of printable ASCII. For this PGP uses radix-64 conversion. Each group of 3 octets of binary data is mapped in to 4 ASCII characters. The use of radix 64 expands a message by 33%

(vi) Segmentation and reassembly

Any message longer than that must be broken up into smaller segments, each of which is mailed separately. At the receiving end, the PGP must strip off all e-mail header and retrieve the essential block.

The header is separated from the body by a blank line, a header line consists of a keyword, followed by a colon followed by keyword's arguments.

Date:

From:

To:

Subject:

S/MIME

S/MIME is a security enhancement to MIME. S/MIME will emerge as the industry standard for commercial and organizational use.

To understand the S/MIME, we need first to have a general understanding of the e-mail format RFC822.

RFC822

RFC 822 defines a format for text messages that are sent using e-mail. In RFC 822 messages are said to have an envelope and contents.

Envelop: Information needed for transmission and delivery is present.

Content: It contains the object to be delivered to the receiver.

Each line in the header consists of a keyword such as ***From, To, Subject, Date.***

Limitations of SMTP/RFC 82:

- SMTP cannot transmit executable or other binary data.
- SMTP cannot transmit text data that includes natural language characters.
- SMTP server may reject mail message over a certain type

Overview of MIME

1. Five new message header fields are defined, which may be included in an RFC 822 header.
2. A number of content formats are defined, thus standardizing representations that support multimedia electronic mail.
3. Transfer encodings are defined that enable the conversion of any content format into a form that is protected from alteration by the mail system.

The five header fields defined in MIME are as follows

MIME-Version: This field must have a parameters value of 1.

Content-Type: This deals with the definition of variety of content types. In general content type specifies the type of data.

Content-Transfer-Encoding: Indicates the type of transformation that has been used to represent the body of the message.

Content-ID: Used to identify MIME entities.

Content-Description: A text description of the object within the body.

Content-Type

There are seven different major types of content and total of 15 subtypes.

Type	Subtype	Description
Text	Plain	Unformatted text;
	Enriched	Provides greater format flexibility.
Multipart	Mixed	The different parts are independent but are to be transmitted together. They should be presented to the receiver in the order that they appear in the mail message.

	Parallel	The multiple parts can be presented in parallel. For example, picture or text part could be accompanied by voice message.
	Alternative	The different representation of the same information.
	Digest	Similar to Mixed, but the default type/subtype of each part is message/ rfc822.
Message	rfc822	The body is itself an encapsulated message.
	Partial	Used to allow fragmentation of large mail items.
	External-body	Contains a pointer to an object that exists elsewhere.
Image	jpeg	The image is in JPEG format.
	gif	The image is in GIF format.
Video	mpeg	MPEG format.
Audio	Basic	Single-channel 8-bit ISDN.
Application	PostScript	Adobe Postscript.
	octet-stream	General binary data consisting of 8-bit bytes.

MIME Transfer Encodings

The objective is to provide reliable delivery across a largest range of environments.

7bit	The data are all represented by short lines of ASCII characters.
8bit	The lines are short, but there may be non-ASCII characters.
Binary	The lines are not necessarily short enough and non-ASCII characters.
quoted-printable	Data being encoded are mostly ASCII text.
base64	Encodes data by mapping 6-bit blocks of input to 8-bit blocks of output, all of which are printable ASCII characters.
x-token	A named nonstandard encoding.

S/MIME functionality

S/MIME provides the following functions

Enveloped Data: This consists of encrypted content of any type and encrypted content encryption keys for one or more recipients.

Signed Data: A digital signature is formed by taking the message digest of the content to be signed and then encrypting that with the private key of the signer. The content plus signature are then encoded using base 64 encoding.

Clear-signed Data: The digital signature is encoded using base64. As a result recipients without S/MIME capability can view the message content, although they cannot verify the signature.

Signed and enveloped data: Signed only and encrypted only entities may be nested, so that encrypted data may be signed.

S/MIME messages

S/MIME secures a MIME entity with a signature, encryption or both.

Type	Subtype	smime Parameter	Description
Multipart	Signed		A clear-signed message in two parts: one is the message and the other is the signature.
Application	pkcs 7-mime	signedData	A signed S/MIME entity.
	pkcs 7-mime	envelopedData	An encrypted S/MIME entity
	pkcs 7-mime	degenerate signedData	s An entity containing only public-key certificates.
	pkcs 7-mime	CompressedData	A compressed S/MIME
	pkcs 7- signature	signedData	The content type of the signature subpart of a multipart/signed message.

Content Type of S/MIME

Enveloped Data

The steps for preparing an enveloped Data are as follows

1. Generate a pseudo-random session key for a particular symmetric encryption algorithm.
2. For each recipient, encrypt the session key with the recipient's public RSA key.
3. For each recipient, prepare a block known as RecipientInfo that contains the sender's public- key certificate, an identifier for the algorithm used to encrypt the session key, and the encrypted session key.
4. Encrypt the message content with the session key.

SignedData

The steps for preparing a signedData MIME entity are as follows:

1. Select a message digest algorithm.
2. Compute the message digest, or hash function, of the content to be signed.
3. Encrypt the message digest with the signer's private key.
4. Prepare a block known as SignerInfo that contains the signer's public-key certificate, an identifier of the message digest algorithm, an identifier of the algorithm used to encrypt the message digest, and the encrypted message digest.

S/MIME Certificate Processing

S/MIME user has several key-management functions to perform:

Key generation: Must be capable of generating separate Diffie-Hellman and DSS key pairs and should be capable of generating RSA key pairs. Each key pair must be generated from a good source of nondeterministic random input and be protected in a secure fashion.

Registration: A user's public key must be registered with a certification authority in order to receive an X.509 public-key certificate.

Certificate storage and retrieval: The list of certificates could be maintained by the user or by some local administrative entity on behalf of a number of users.

VeriSign Certificates

VeriSign provides a service that is intended to be compatible with S/MIME and a variety of other applications. VeriSign issues X.509 certificates with the product name VeriSign Digital ID. Each digital ID contains

- Owner's public key
- Owner's name or alias
- Expiration date of the Digital ID
- Serial number of the Digital ID
- Name of the certification authority that issued the Digital ID

Enhanced Security Services

- Signed Receipts
- Security Labels
- Secure Mailing Lists

IP SECURITY (IPSec)

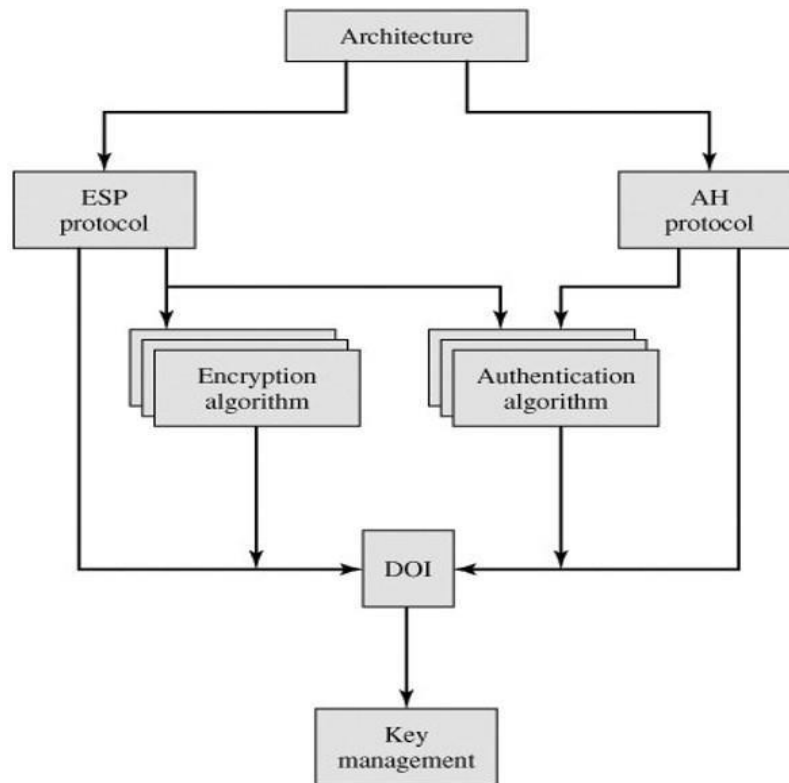
IPSec provides the capability to secure communications across a LAN, across private and public WANs, and across the Internet. Examples are

- Secure branch office connectivity over the Internet
- Secure remote access over the Internet
- Establishing extranet and intranet connectivity with partners
- Enhancing electronic commerce security

IP Security Architecture

The IPSec specification consists of numerous documents. The most important of these, issued in November of 1998, are

- RFC 2401: An overview of a security architecture
- RFC 2402: Description of a packet authentication extension to IPv4 and IPv6
- RFC 2406: Description of a packet encryption extension to IPv4 and IPv6
- RFC 2408: Specification of key management capabilities



IPSec Document Overview

Architecture: Covers the general concepts, security requirements, definitions, and mechanisms defining IPSec technology.

Encapsulating Security Payload (ESP): Covers the packet format and general issues related to the use of the ESP for packet encryption and, optionally, authentication.

Authentication Header (AH): Covers the packet format and general issues related to the use of AH for packet authentication.

Encryption Algorithm: A set of documents that describe how various encryption algorithms are used for ESP.

Authentication Algorithm: A set of documents that describe how various authentication algorithms are used for AH and for the authentication option of ESP.

Key Management: Documents that describe key management schemes.

Domain of Interpretation (DOI): This document contains values needed for other documents to relate to each other.

IPSec Services

IPSec provides security services at the IP layer by enabling a system to select required security protocols. Two protocols are used to provide security:

- Authentication protocol
- Encryption/authentication protocol (ESP).

The services are

- Access control
- Connectionless integrity

- Data origin authentication
- Rejection of replayed packets (a form of partial sequence integrity)
- Confidentiality (encryption)
- Limited traffic flow confidentiality

Security Associations

An association is a one-way relationship between a sender and a receiver that affords security services to the traffic carried on it. If security exchange is needed in both directions then two-way security association is needed. A security association is uniquely identified by three parameters:

Security Parameters Index (SPI): A bit string assigned to this SA.

IP Destination Address: Only unicast addresses are allowed.

Security Protocol Identifier: This indicates whether the association is an AH or ESP security association

SA Parameters

A security association is normally defined by the following parameters:

Sequence Number Counter: A 32-bit value used to generate the Sequence Number field in AH or ESP headers.

Sequence Counter Overflow: A flag indicating whether overflow of the Sequence Number Counter should generate an auditable event and prevent further transmission of packets on this SA.

Anti-Replay Window: Used to determine whether an inbound AH or ESP packet is a replay or not.

AH Information: Specifies authentication related parameters like authentication algorithm, authentication key, and key lifetimes.

ESP Information: Specifies the encryption and authentication algorithm, keys, initialization values, key lifetimes

Lifetime of this SA: This is the time interval after which SA must be replaced with a new SA.

IPSec Protocol Mode: This parameter specifies the mode of transfer.

Path MTU: Specifies the maximum transmission unit.

SA Selectors

IPSec provides the user with flexibility in the way in which IPSec services are applied to IP traffic. The means by which IP traffic is related to specific SAs is the nominal Security Policy Database (SPD). SPD contains entries, each of which defines a subset of IP traffic and points to an SA for that traffic. Each SPD entry is defined by a set of IP and upper-layer protocol field values, called selectors. These selectors are used to filter outgoing traffic in order to map it into a particular SA.

The following selectors determine an SPD entry:

- Destination IP Address
- Source IP Address
- UserID
- Data Sensitivity Level

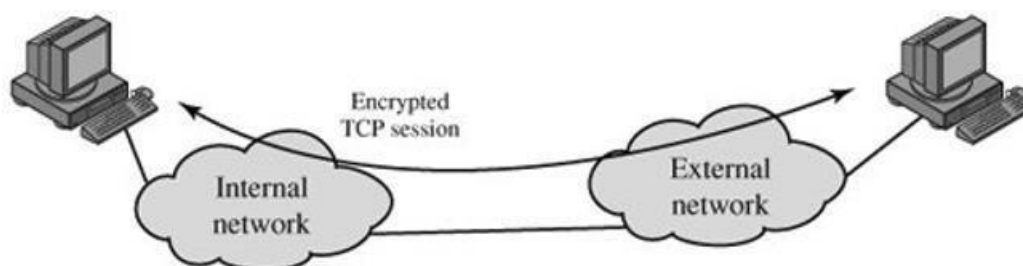
- Transport Layer Protocol
- Source and Destination Ports

Modes of Transfer

- Transport Mode
- Tunnel Mode

Transport Mode

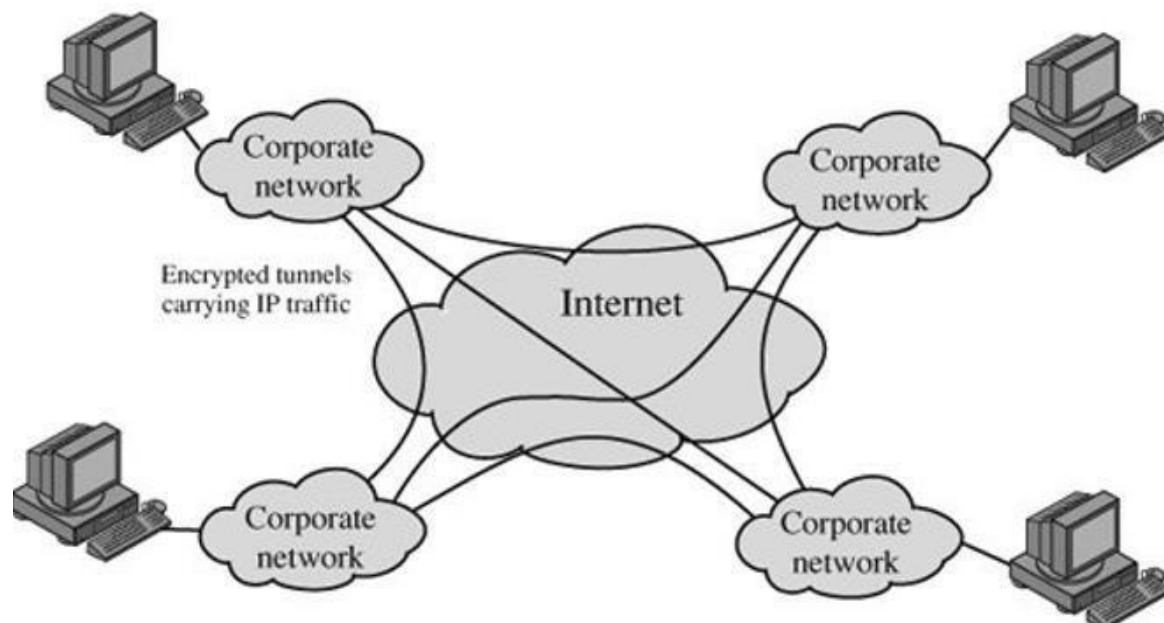
Transport mode provides protection primarily for upper-layer protocols. The transport mode protection extends to the payload of an IP packet. Transport mode is used for end to end connections.



(a) Transport-level security

Tunnel Mode

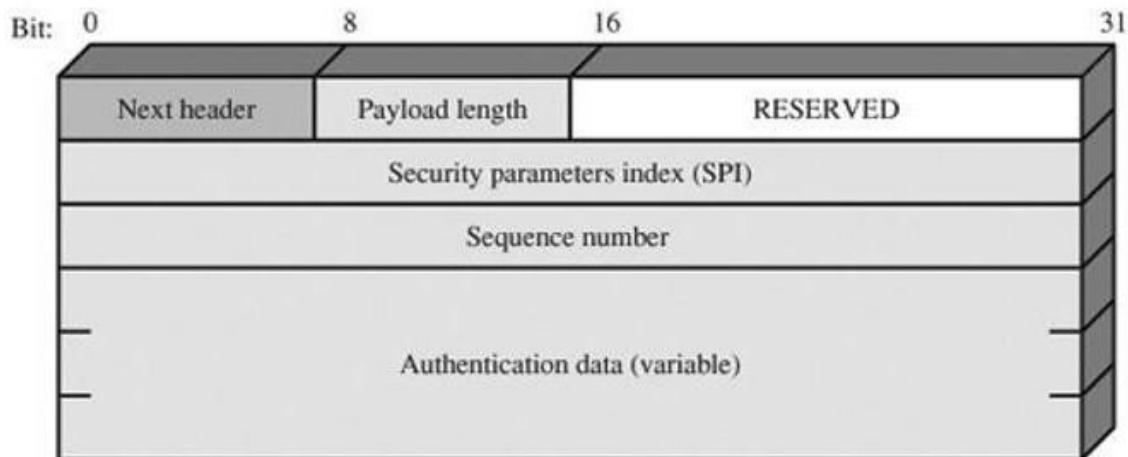
Tunnel mode provides protection to the entire IP packet. Tunnel mode authenticates the entire inner IP and selected portion of outer IP header, IP V6 extension header.



(b) A virtual private network via tunnel mode

AUTHENTICATION HEADER

The Authentication Header provides data integrity and authentication of IP packets. The data integrity assures that modification during transit is not possible. The authentication enables



the system to authenticate the user and prevents the address spoofing attacks.

IP Authentication Header

The Authentication Header consists of the following fields

Next Header (8 bits): Identifies the type of header immediately following this header.

Payload Length (8 bits): Length of Authentication Header in 32-bit words, minus 2.

Reserved (16 bits): For future use.

Security Parameters Index (32 bits): Identifies a security association.

Sequence Number (32 bits): A monotonically increasing counter value.

Authentication Data (variable): A variable-length which contains the Integrity Check Value.

Anti-Replay Service

A replay attack is one in which an attacker obtains a copy of an authenticated packet and later transmits it to the intended destination. The Sequence Number field is designed to overcome such attacks.

Generation of sequence number by the sender

When a new SA is established, the sender initializes a sequence number counter to 0. Each time that a packet is sent on this SA, the sender increments the counter and places the value in the Sequence Number field. Thus, the first value to be used is 1. If anti-replay is enabled the sender must not allow the sequence number field to come back to 0, after cycle past $2^{32} - 1$. If the limit of $2^{32} - 1$ is reached, the sender should terminate this SA and negotiate a new SA with a new key.

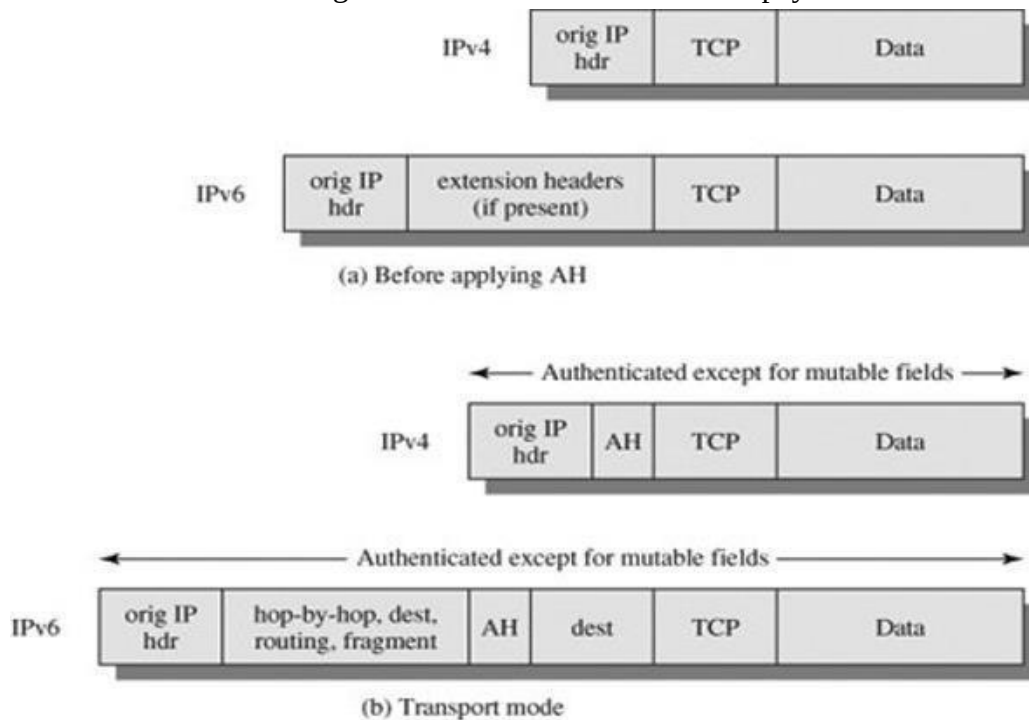
For any incoming packet, the processing

1. If the received packet falls within the window and is new, the MAC is generated.

2. If the packet is authenticated, the corresponding slot in the window is marked as received.
3. If the received packet is to the left of the window, or if authentication fails, the packet is discarded.

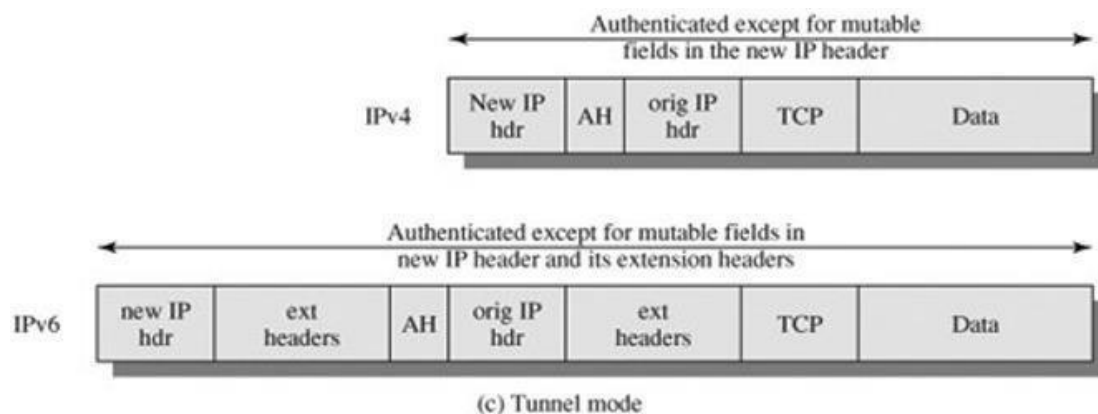
Transport mode AH

The AH is inserted after the original IP header and before the IP payload.



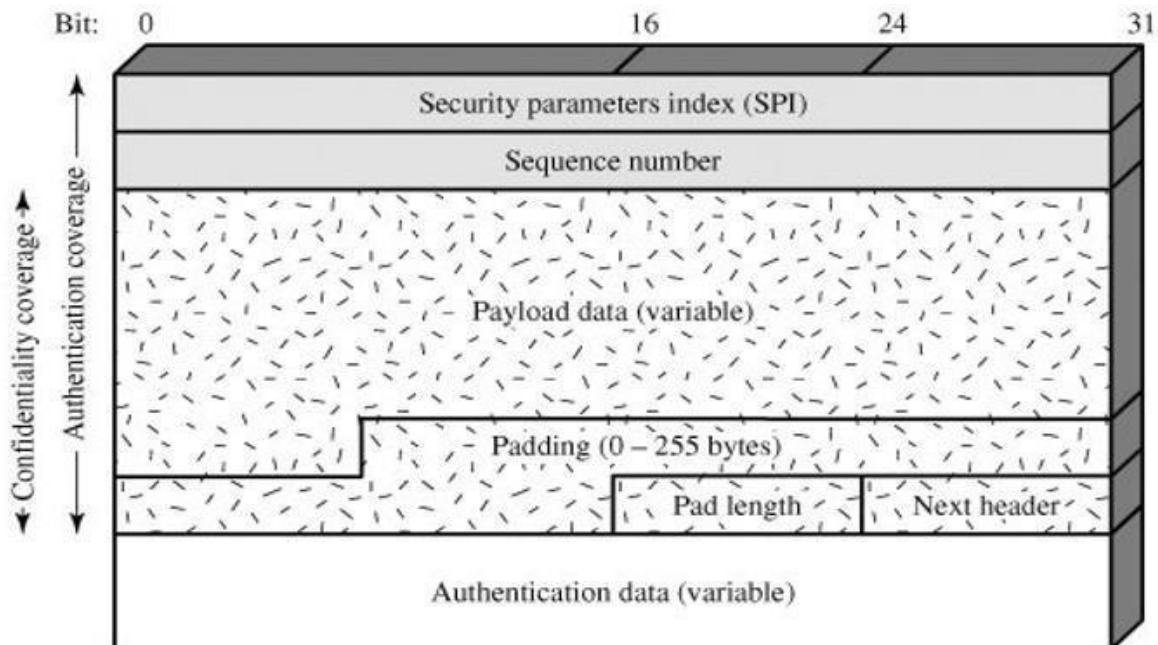
Tunnel Mode of AH

The entire original IP packet is authenticated and the AH is inserted between the original IP header and new IP header.



ENCAPSULATING SECURITY PAYLOAD

The Encapsulating Security Payload provides confidentiality of message contents and limited for traffic flow confidentiality.



Security Parameters Index (32 bits): Identifies a security association.

Sequence Number (32 bits): A monotonically increasing counter value; this provides an anti-replay function.

Payload Data (variable): This is a transport-level segment or IP packet protected by encryption.

Padding (0-255 bytes): The purpose of this field is discussed later.

Pad Length (8 bits): Indicates the number of pad bytes immediately preceding this field.

Next Header (8 bits): Identifies the type of data contained in the payload data field by identifying the first header in that payload.

Authentication Data (variable): A variable-length field that contains the Integrity Check Value computed over the ESP packet minus the Authentication Data field.

Encryption and Authentication Algorithms

The Payload Data, Padding, Pad Length, and Next Header fields are encrypted by the ESP service. The algorithms used for encryption are

- Triple DES
- RC5
- IDEA
- Three-key triple IDEA
- CAST
- Blowfish

The uses of Padding are

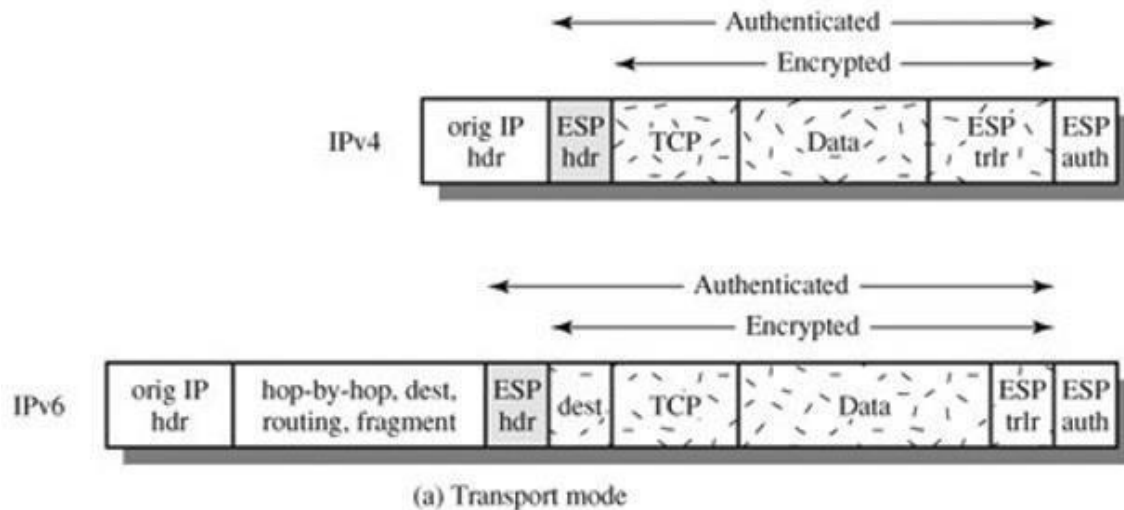
- (i) If an encryption algorithm needs the plaintext to be a multiple of some number of bytes, the Padding is needed.
- (ii) The ESP format requires that the Pad Length and Next Header fields be right

aligned within a 32bit word.

- (iii) The padding conceals the actual length of payload thus brings confidentiality.

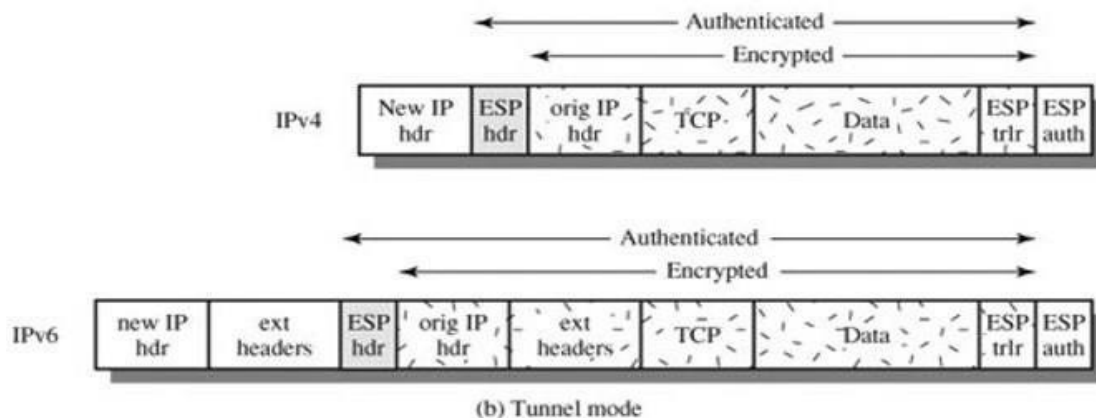
Transport Mode ESP

Transport mode ESP is used for encryption and authentication of data.



Tunnel Mode ESP

Tunnel mode ESP is used to encrypt an entire IP packet. The tunnel mode is useful for



firewall or security gateway that protects the trusted network from external networks.

KEY MANAGEMENT [Not in syllabus]

The key management portion of IPSec involves the determination and distribution of secret keys. The IPSec support two types of key management:

Manual: A system administrator manually configures each system with its own keys and with the keys of other communicating systems.

Automated: This system supports on-demand creation of keys for SAs and supports use of large system. The automated key management protocol for IPsec is called **ISAKMP/Oakly**.

ISAKMP (Internet Security Association Key Management Protocol)

ISAKMP defines procedures and formats to establish, negotiate, modify, and delete security

associations. ISAKMP defines payload for exchanging key generation and authentication data.

Initiator Cookie (64 bits): Cookie of entity that initiated SA establishment, SA notification, or SA deletion.

Responder Cookie (64 bits): Cookie of responding entity; null in first message from initiator.

Next Payload (8 bits): Indicates the type of the first payload in the message.

Major Version (4 bits): Indicates major version of ISAKMP in use.

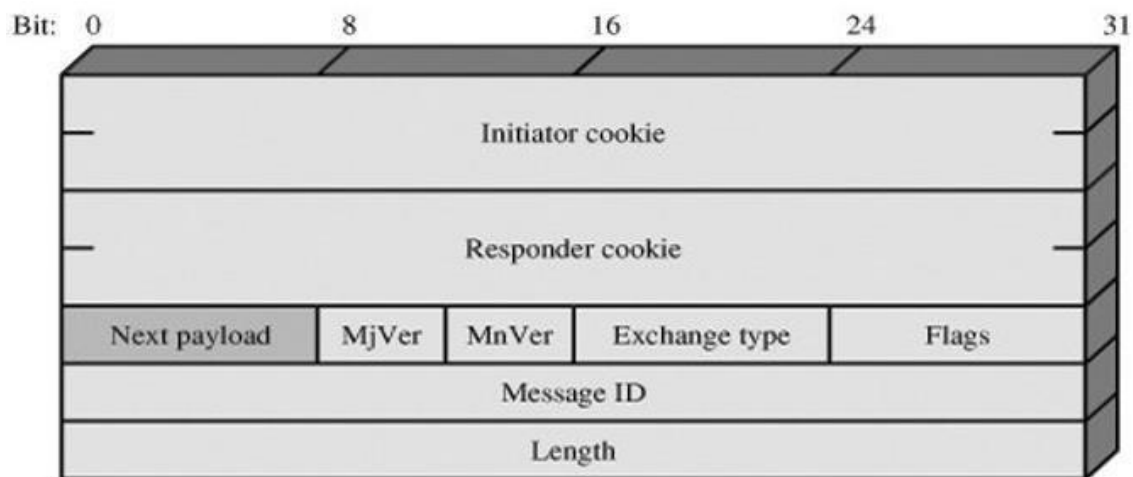
Minor Version (4 bits): Indicates minor version in use.

Exchange Type (8 bits): Indicates the type of exchange.

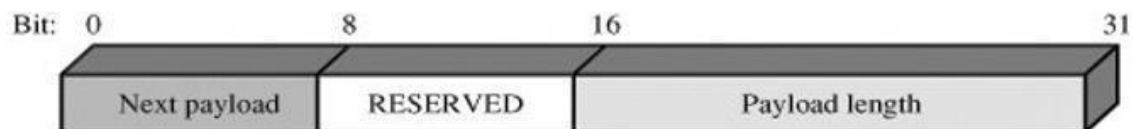
Flags (8 bits): Indicates specific options set for this ISAKMP exchange.

Message ID (32 bits): Unique ID for this message.

Length (32 bits): Length of total message (header plus all payloads) in octets.



(a) ISAKMP header



(b) Generic payload header

ISAKMP Payload Types

Type	Description
Security Association (SA)	Used to negotiate security attributes and indicate the DOI and Situation under which negotiation is taking place.
Proposal (P)	Used during SA negotiation; indicates protocol to be used and number of transforms.
Transform (T)	Used during SA negotiation; indicates transform and related SA attributes.
Key Exchange (KE)	Supports a variety of key exchange techniques.
Identification (ID)	Used to exchange identification information
Certificate (CERT)	Used to transport certificates and other certificate- related information.

Certificate Request (CR)	Used to request certificates; indicates the types of certificates requested and the acceptable certificate authorities.
Hash (HASH)	Contains data generated by a hash function.
Signature (SIG)	Contains data generated by a digital signature function.
Nonce (NONCE)	Contains a nonce.
Notification (N)	Used to transmit notification data, such as an error condition.
Delete (D)	Indicates an SA that is no longer valid.

ISAKMP messages

Responder-Lifetime: Communicates the SA lifetime chosen by the responder.

Replay-Status: Used for positive confirmation of the responder's election of whether or not the responder will perform anti-replay detection.

Initial-Contact: Informs the other side that this is the first SA being established with the remote system.

The Delete payload: Indicates that the sender has deleted the SA from its database.

ISAKMP Exchanges

The Base Exchange: Allows key exchange and authentication to be transmitted together.

The Identity Protection Exchange: Expands the base to protect the users' identities.

The Authentication Only Exchange: Used to perform mutual authentication, without a key exchange.

The Aggressive Exchange: Provides identity protection.

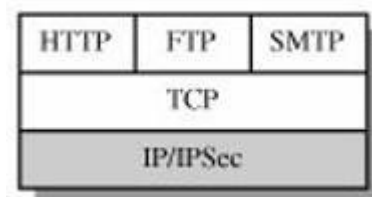
The Informational Exchange: Used for one-way transmittal of information for SA management.

WEB SECURITY

The web security threats can be found in web browser and the network traffic between the browser and server.

Web Traffic Security Approaches

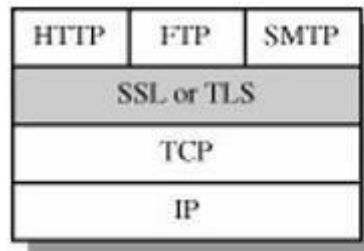
Approach1



(a) Network level

This approach is transparent to end users and provides a general-purpose solution. IPsec data filtering, so that only selected traffic can incur IPsec processing.

Approach 2

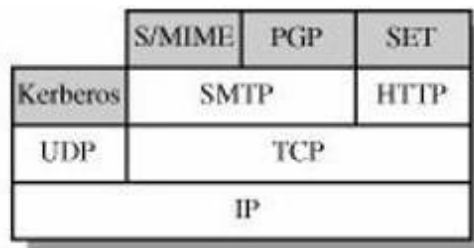


(b) Transport level

Implement the security above TCP. SSL can be embedded with SSL to Netscape Navigator, Microsoft explorer.

Approach 3

Security services are embedded in a particular application. SET is an example of this approach.

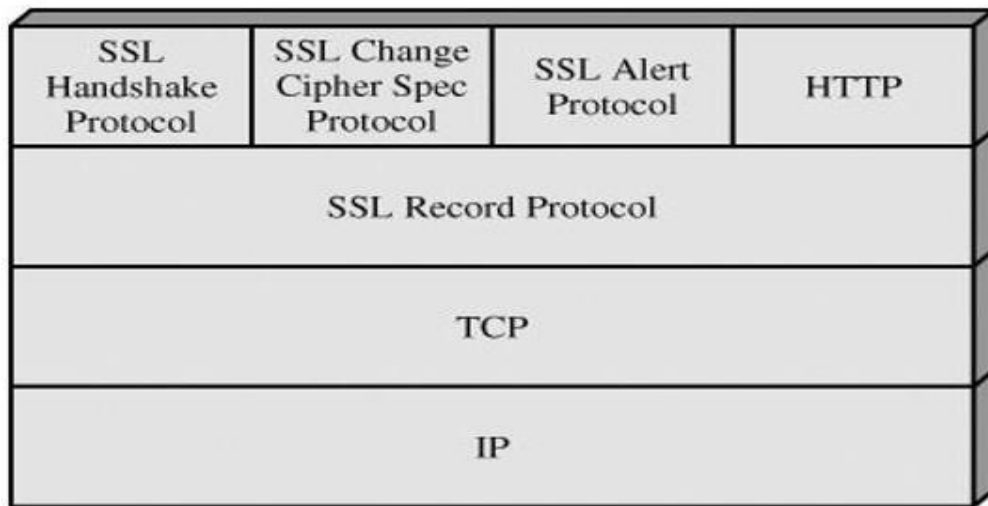


(c) Application level

SECURE SOCKET LAYER (SSL)

SSL originated from Netscape.

SSL Architecture



The SSL Record Protocol provides basic security services to various higher-layer protocols.

Three higher layer protocols are part of SSL are

- Handshake Protocol
- Change Cipher Specification Protocol
- Alert Protocol

SSL concepts

Two important SSL concepts are

- SSL session
- SSL connection

Parameters of a session state

Session identifier: An arbitrary byte sequence chosen by the server to identify an active or resumable session state.

Peer certificate: An X509.v3 certificate of the peer.

Compression method: The algorithm used to compress data prior to encryption.

Cipher spec: defines cryptographic attributes such as the hash size.

Master secret: 48-byte secret shared between the client and server.

Is resumable: A flag indicating whether the session can be used to initiate new connections

Parameters that define the connection state

- Server and client random
- Server write MAC secret:
- Client write MAC secret
- Server write key
- Client write key
- Initialization vectors
- Sequence numbers

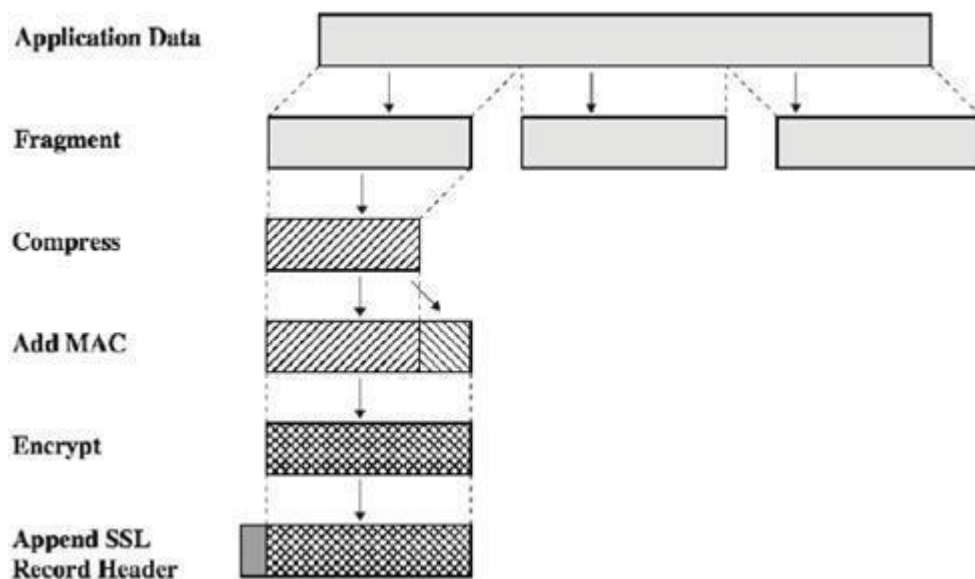
SSL protocol stack

The SSL Record Protocol provides two services for SSL connections:

Confidentiality: The Handshake Protocol defines a shared secret key that is used for conventional encryption of SSL payloads.

Message Integrity: The Handshake Protocol also defines a shared secret key that is used to form a message authentication code (MAC).

SSL record protocol operations



The Record Protocol takes an application message to be transmitted, fragments the data into manageable blocks, optionally compresses the data, applies a MAC, encrypts, adds a header, and transmits the resulting unit in a TCP segment. Received data are decrypted, verified, decompressed, and reassembled and then delivered to higher-level users.

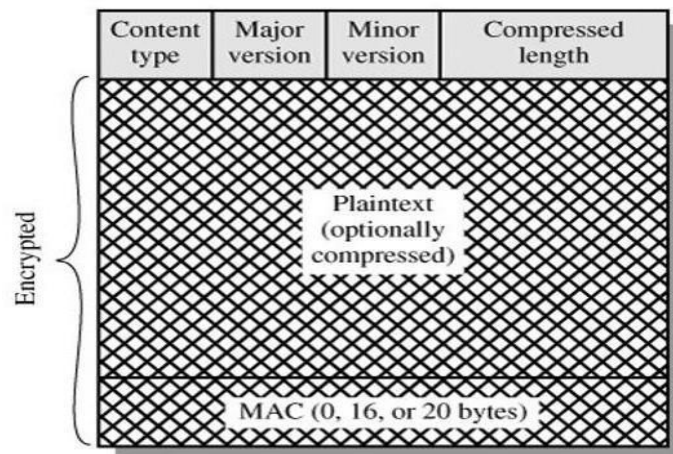
SSL record format

Content Type (8 bits): The higher layer protocol used to process the enclosed fragment.

Major Version (8 bits): Indicates major version of SSL in use which is 3.

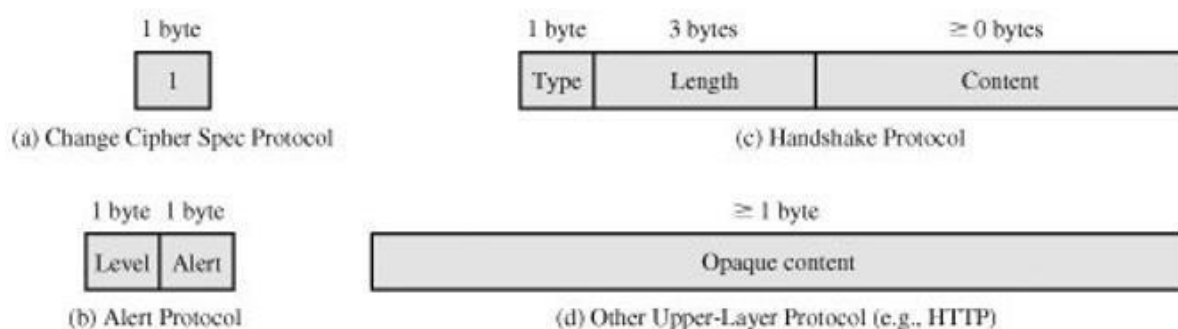
Minor Version (8 bits): Indicates minor version in use which is 0.

Compressed Length (16 bits): The length in bytes of the plaintext fragment, maximum value is $2^{14} + 2048$.



Change Cipher Specification Protocol

This protocol consists of a single message which consists of a single byte with the value 1. The sole purpose of this message is to cause the pending state to be copied into the current state, which updates the cipher suite to be used on this connection.



Alert Protocol

The Alert Protocol is used to convey SSL-related alerts to the peer entity. The SSL messages are compressed and encrypted, as specified by the current state. The alerts are

unexpected_message: An inappropriate message was received.

bad_record_mac: An incorrect MAC was received.

decompression_failure: The decompression function received improper input

handshake_failure: Sender was unable to negotiate an acceptable set of security parameters given the options available.

Handshake Protocol

The Handshake Protocol consists of a series of messages exchanged by client and server

Phase 1: Establish Security Capabilities

This phase is used to initiate a logical connection and to establish the security capabilities that will be associated with it. The exchange is initiated by the client by sending the 'client hello' message. It contains the

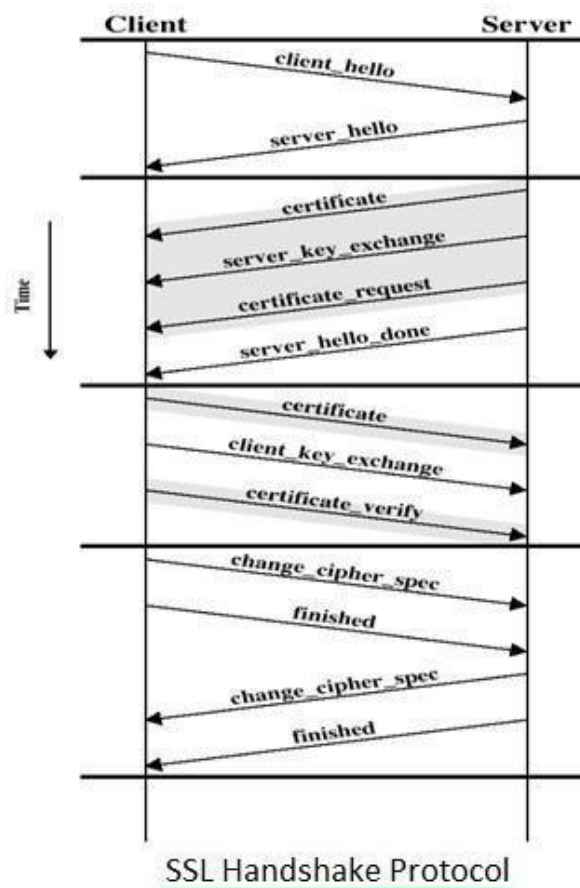
- Version
- Random
- Session id

- Cipher Suite
- Compression Method

The server also sends a 'server hello' message to the client.

Phase 2: Server Authentication and Key Exchange

- The server sends its certificate, if it needs to be authenticated.
- Server key exchange message is optional.
- Server requests a certificate from the client.
- 'Server done' is sent by the server to indicate the end of server hello and associated messages. After this message the server will not wait for the client response.



Phase 3. Client Authentication and Key Exchange

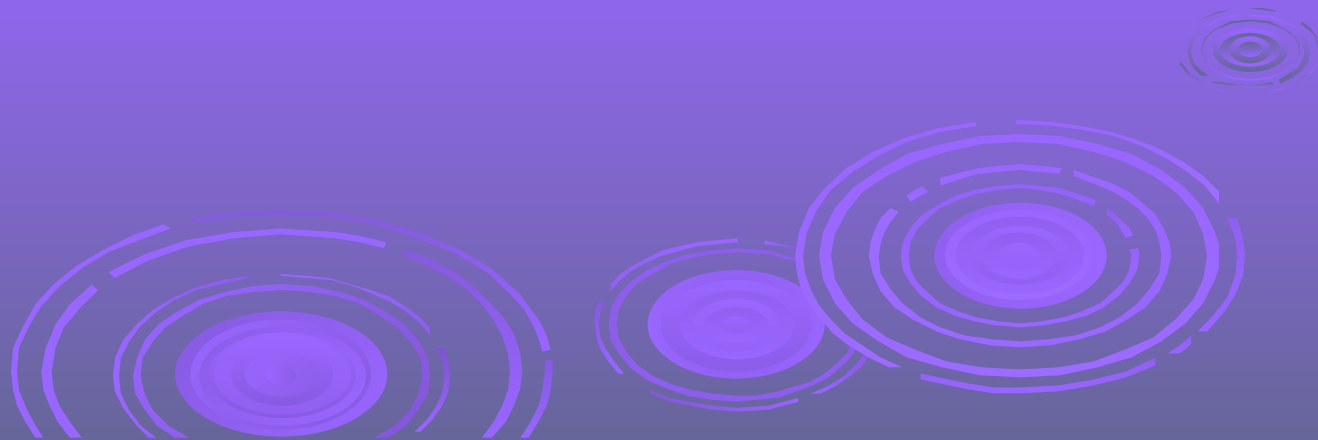
The client should verify that the server provided a valid certificate. If all details are satisfied the client sends one or more messages back to the server.

Phase 4. Finish

The client sends a `change_cipher_spec` message and copies the pending CipherSpec into the current CipherSpec. The client then immediately sends the `finished` message under the new algorithms, keys, and secrets. The `finished` message verifies that the key exchange and authentication processes were successful.

In response to these two messages, the server sends its own `change_cipher_spec` message, transfers the pending to the current CipherSpec, and sends its `finished` message. Now, the handshake is complete and the client and server exchange data.

CASE Study – UPI Transaction



UPI

Unified Payment Interface is a system that provides an architecture and standard set of APIs to facilitate the online immediate payments. Core features of UPI :

- ❖ Open Source
- ❖ Mobile First
- ❖ Interoperable
- ❖ Instantaneous
- ❖ Secure
- ❖ Cheap
- ❖ Simple
- ❖ Innovative
- ❖ Easily Adaptable

- Real Time Payment System
- Regulated by Reserve Bank of India
- Simple, easy and quick payment transactions using UPI
- Account to Account payment instantly
- Collect money using Mobile number or Payment address

Why UPI

Mobile Payments have not
scaled up in the country

Using Aadhaar number, mobile
number, card number, virtual
address and account number in a
unified way

Virtual Payment Address

Secure MPIN entry on NPCI
libraries

Push /Pull
Remote/Proximity

Authentication by MPIN and
Biometric

Mobile App
Merchant
Remittance including P2P
ECommerce

Single Click 2 Factor
Authentication

KEY ASPECTS OF UPI

- ▶ The Unified Payment Interface is expected to further propel easy instant payments via mobile, web, and other applications.
- ▶ The payments can be both sender (payer) and receiver (payee) initiated and are carried out in a secure, convenient, and integrated fashion.
- ▶ This design provides an ecosystem driven scalable architecture and a set of APIs taking full advantage of mass adoption of smartphone.
- ▶ Virtual payment addresses, 1-click 2-factor authentication, Aadhaar integration, use of payer's smartphone for secure credential capture, etc. are some of the core features.
- ▶ It allows banks and other players to innovate and offer a superior customer experience to make electronic payments convenient and secure.
- ▶ Supports the growth of e-commerce, while simultaneously meeting the target of financial inclusion.
- ▶ Proposed architecture is well within the regulatory framework of the mobile and ecommerce transactions having 2 factors of authentication (2FA).

Virtual Payment Address features

- ❖ **Unique** mapping to Identifier (Person / Entity).
- ❖ **Global Identifier** (Adhaar number and Mobile Number).
- ❖ Apps can offer multiple virtual address to customers.
- ❖ Pay and Collect Money.
- ❖ Standard set of APIs.
- ❖ **1-click 2- factor authentication.**

Normalized Architecture for payment address “account @ provider”

The address must include : ‘ a – z ‘ , ‘ A – Z ‘ , ‘ 0 – 9 ‘ , ‘ . (dot) ‘ , ‘ – (hyphen) ’ .

- ❖ The Payment Address can be issues by :

Bank : shyam.444@icici

PSP : abdul2014.irctc@mypsp PPI :
000012346789@myppi

- ❖ NPCI (using global identifiers)

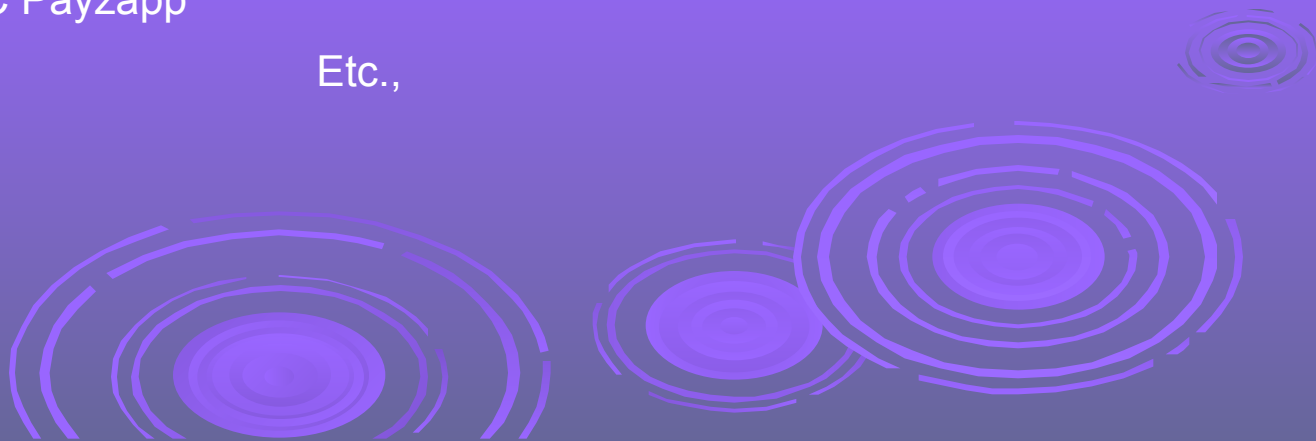
- IFSC code and account number as account-no@ifsc-code.ifsc.npci
e.g. 12345@HDFC0000001.ifsc.npci
- Adhaar number as aadhaar-no@aadhaar.npci
e.g. 234567890123@aadhaar.npci
- Mobile Number as mobile-no@mobile.npci
e.g. 9800011111@mobile.npci



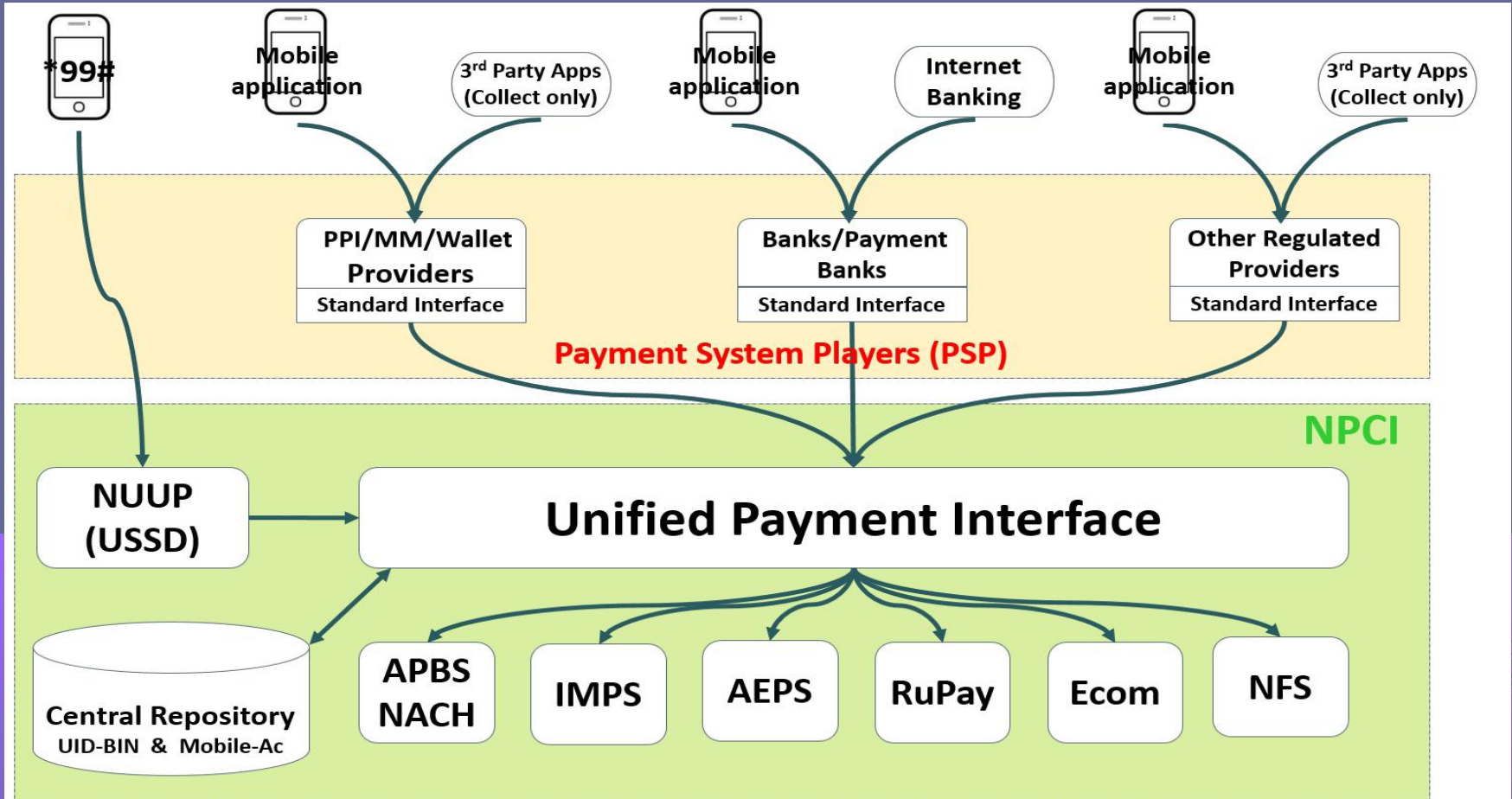
List of Applications

1. Phonepe
2. Google Pay
3. Paytm
4. BHIM UPI
5. Mobikwik
6. Airtel Payments Bank
7. Axis Pay
8. SBI UPI
9. I Mobile
10. HDFC Payzapp

Etc.,



ARCHITECTURE OF UPI

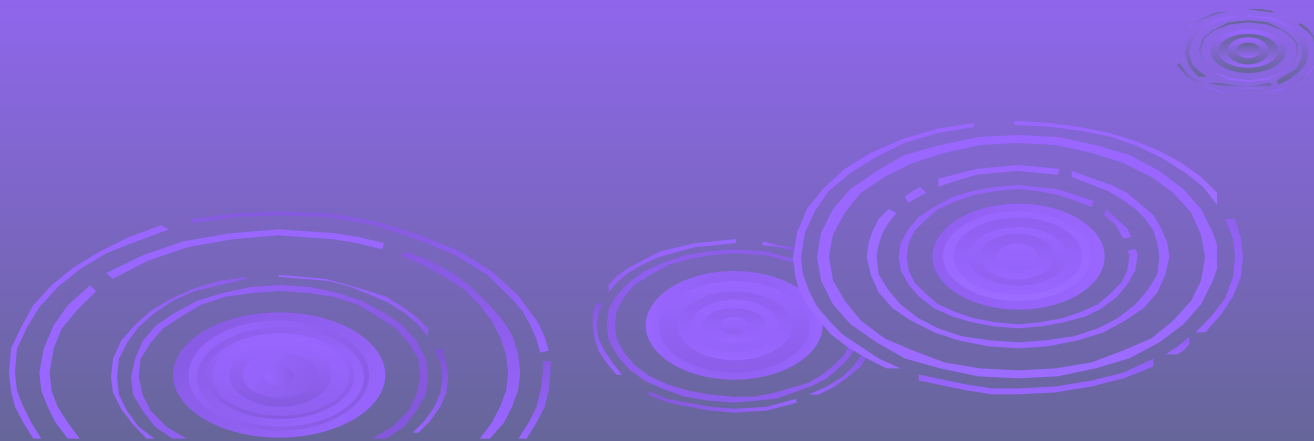


Core Elements in Payment

- ❖ Payer and Payee account and institution details for routing transaction.
- ❖ Authentication credentials (password, PIN, biometrics, CVV, etc. as required for debit, can be bank provided or 3rd party provided such as UIDAI).
- ❖ Transaction amount.
- ❖ Transaction reference.
- ❖ Timestamp.
- ❖ Other metadata attributes such as location, product code, mobile number, device details, etc. as required.

Services offered by UPI

1. Send money
2. Request Money
3. Scan and Pay
4. Transactions
5. Profile
6. Bank Account

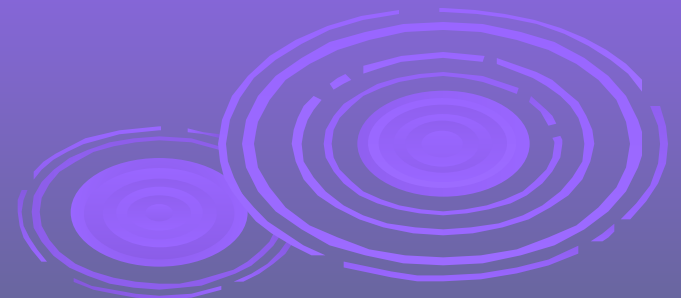


Value proposition

- ▶ Simplifying Authentication
- ▶ Simplifying Issuance Infrastructure
- ▶ Flexibility for Users
- ▶ Enabling 1-click 2-FA Transactions
- ▶ Embracing Mobile Adoption
- ▶ Stimulating Innovation
- ▶ Embracing Aadhaar Adoption
- ▶ Creating National Interoperability

ADHAAR FACILITIES SUPPORTED

- ▶ Aadhaar Authentication
- ▶ Aadhaar e-KYC
- ▶ Aadhaar Enabled Account (AEA)
- ▶ Aadhaar Payment Bridge (APB)
- ▶ Aadhaar Enabled Payment System (AEPS)



Benefits of UPI

Benefits of UPI

01

Free Fund Transfer

02

Useful For Small Purchases

03

Privacy of Bank Account

UPIpayments.co.in

04

More Secure

05

Instant Transfer

06

One App, Many Accounts

07

Various Apps To Choose For

08

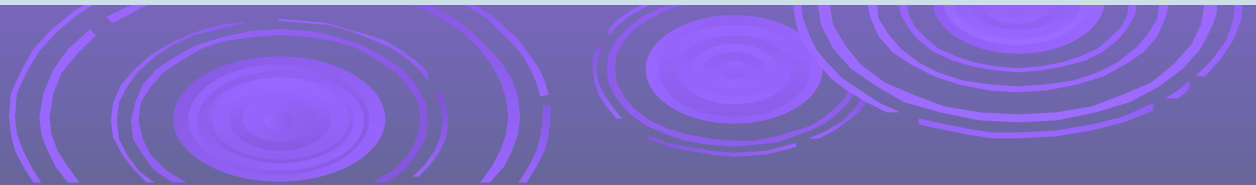
Request Money

09

No Loss of Interest

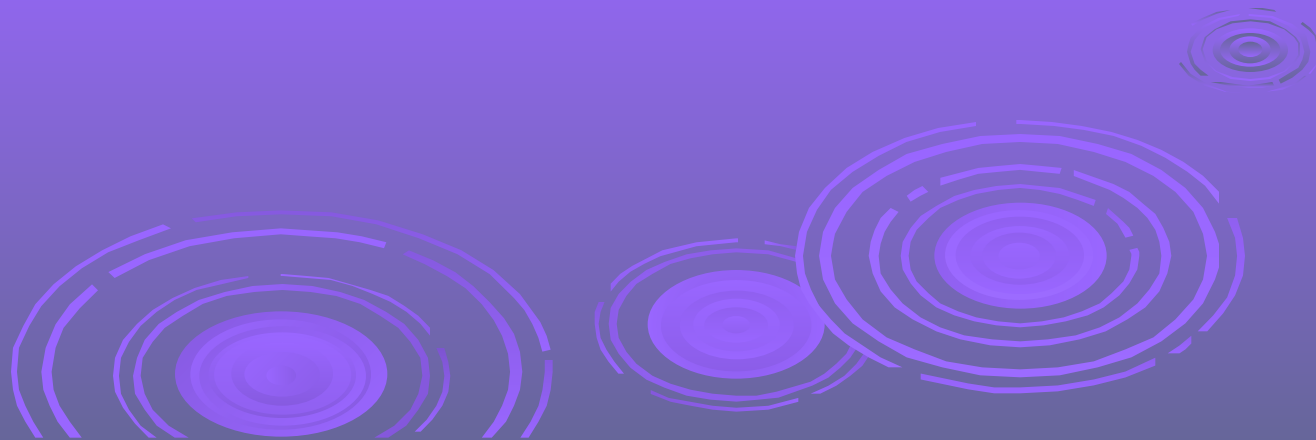
10

Rewards and Cashbacks



Problems

- ❖ Lack of proper security
- ❖ Transaction Limit
- ❖ Maximum amount
- ❖ Requirement of Smart Phone and Internet.



Secure Transaction Architecture for Online Payment System

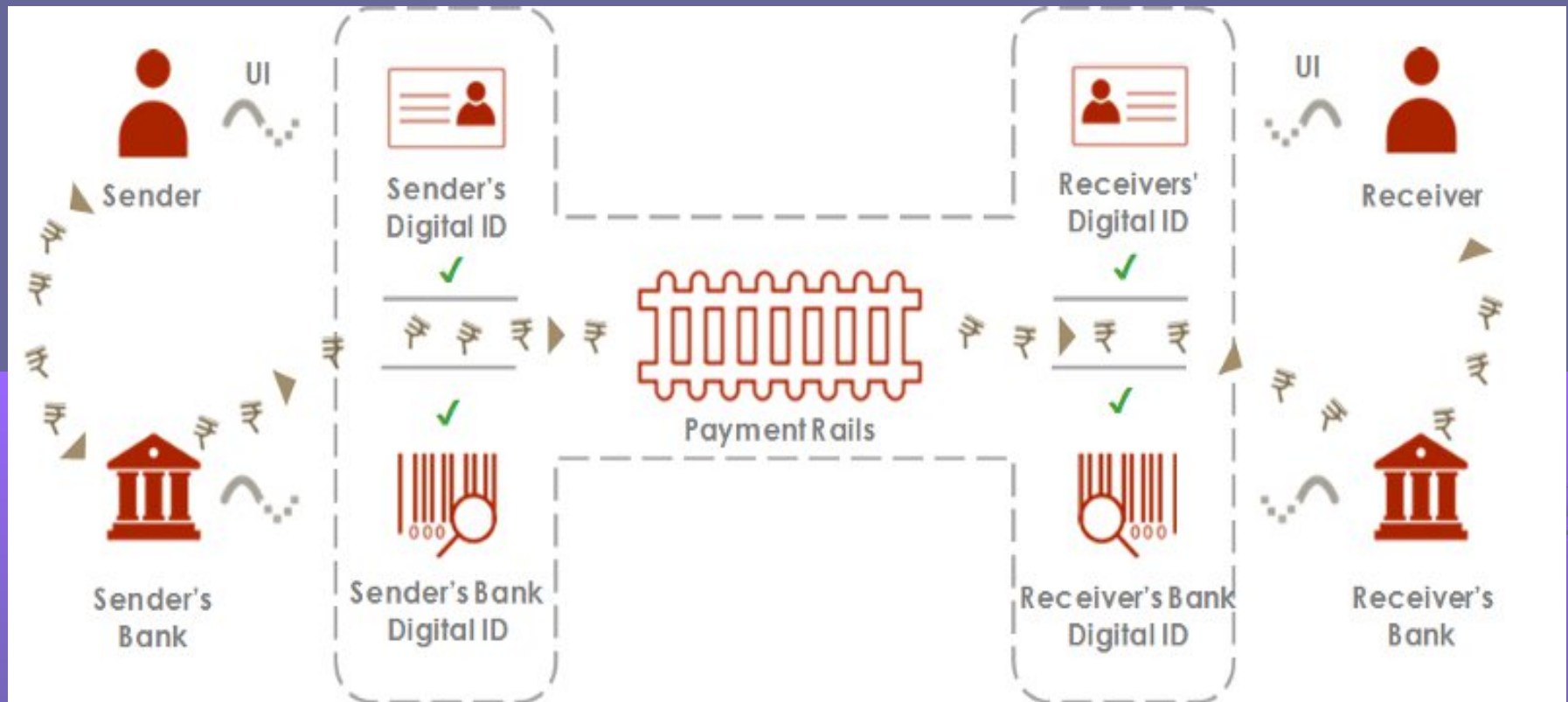
Suitable Security Mechanisms

Security Requirement	Algorithm / Protocol Used	Purpose
Confidentiality	TLS 1.3 + AES-256-GCM	Encrypts transaction data
Authentication	Digital Certificate + OTP/MPIN/Biometric	Verifies server and user
Integrity	SHA-256 / HMAC / GCM Tag	Detects data tampering
Key Exchange	ECDHE	Generates secure session key
Non-repudiation	Digital Signature using ECDSA/RSA	Provides proof of transaction
Replay Protection	Nonce, timestamp, transaction ID	Prevents reuse of old requests

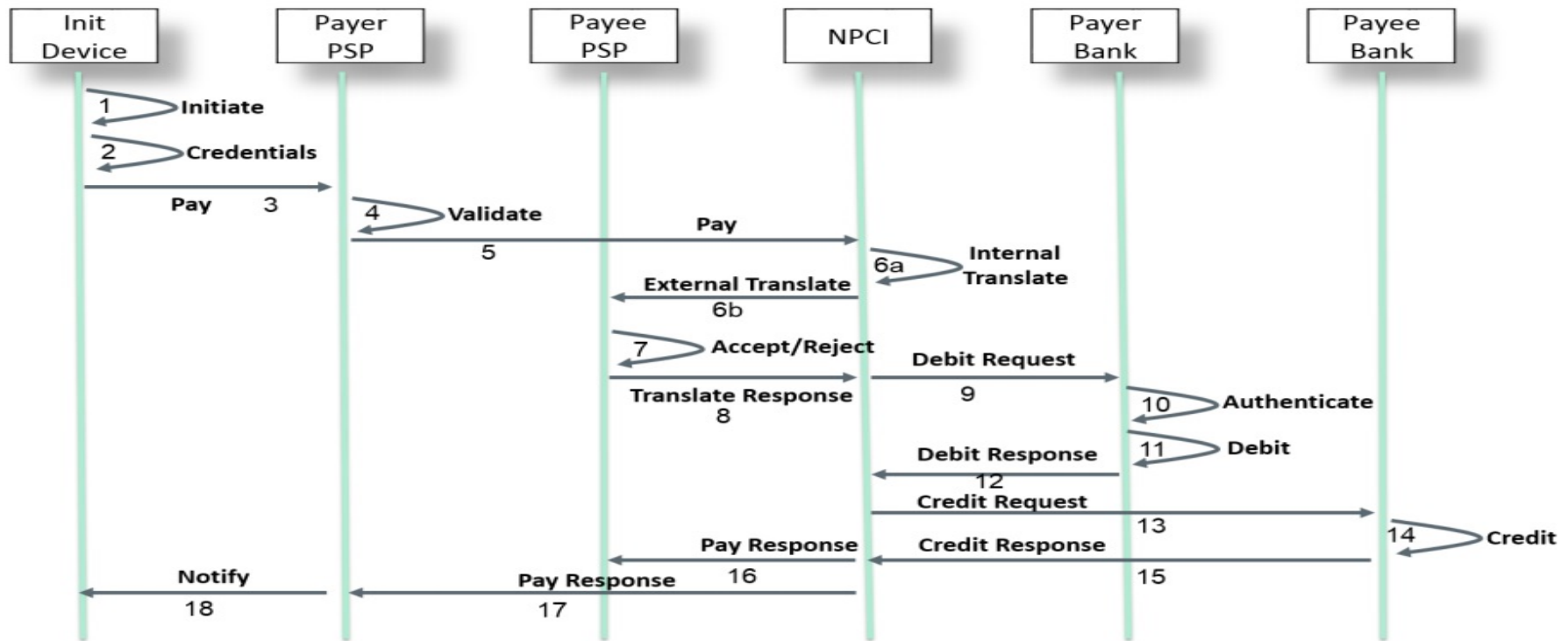


NPCI Central Mapper

- ▶ Aadhaar as the Payment Address
- ▶ Mobile as the Payment Address



Payment Flow



- The payment app first creates a secure communication channel with the payment server using **TLS 1.3**. During the TLS handshake, the server sends its **digital certificate**, which is verified by the client to confirm that the user is communicating with the genuine bank or payment gateway.
- After authentication of the server, **ECDHE key exchange** is used to generate a shared session key. This key is then used with **AES-256-GCM** to encrypt transaction details such as payer ID, payee ID, amount, and transaction ID.
- User authentication is performed using **MPIN, OTP, or biometric verification**. This ensures that only the legitimate user can initiate the payment.
- Integrity is ensured using **GCM authentication tag / HMAC-SHA-256**, which detects any modification in the transaction data. A **nonce, timestamp, and unique transaction ID** are added to prevent replay attacks.
- Finally, the bank or payment server sends a digitally signed response to confirm the transaction status.

SECURITY CONSIDERATIONS

For data security, the following classes of information are defined:

- ▶ **Sensitive Data** - Data such as PIN, passwords, biometrics, etc. These are not to be stored and should only be transported in encrypted form.
- ▶ **Private Data** - Data such as account number. This information may be stored by the PSP, but only in encrypted form.
- ▶ **Non-Sensitive data** - Name, transaction history (amount, timestamp, response code, location, etc.) that can be stored in unencrypted form

Two-Factor Authentication

UPI relies on two primary authentication factors to authorize a transaction:

- **Device Binding:** The UPI application is linked to a user's mobile number, which must be the same as the one registered with their bank account. An encrypted SMS is sent during registration to verify the device and mobile number, creating a "device fingerprint" that ensures transactions can only be initiated from a trusted device.
- **UPI PIN:** A 4- or 6-digit Personal Identification Number (PIN) is required to authorize every financial transaction. This PIN is encrypted and never stored on the app or the merchant's server, making it extremely difficult for fraudsters to access.

SECURITY CONSIDERATIONS

2. End-to-End Encryption

All data transmitted during a UPI transaction, from the user's app to the bank's servers, is encrypted. This prevents unauthorized interception or modification of sensitive information during transit.

3. Real-Time Transaction Monitoring

The NPCI and banks use sophisticated systems to monitor UPI transactions in real-time. These systems can detect and flag suspicious activities, such as multiple failed login attempts, unusual transaction patterns, or transactions from new devices, to prevent fraudulent activities.

Secure Your Device and Network:

- **Use a strong device lock:** Secure your smartphone with a strong password, PIN, or biometric authentication (fingerprint, face ID).
- **Avoid public Wi-Fi:** When making UPI transactions, use a secure, password-protected network or your mobile data. Public Wi-Fi networks can be vulnerable to data interception.

Identity & Account Validation

Identity Data	Validated By	When	How
Mobile Device	PSP & NPCI (via common library)	Customer Registration & during transaction	SMS based OTP initially against the registered mobile and using HOTP/TOTP for implicit verification during every transaction
Aadhaar Number or PAN number	PSP	Customer Registration	Aadhaar e-KYC / Authentication or PAN card verification
Customer Name	PSP	Customer Registration	Aadhaar e-KYC / Demographic Authentication, matching with PAN card verification
Account Details - Number, Account Ownership,	PSP	Every time a payment account is added	Ideally via an API offered by account providers or via a small value (e.g. Rs.1/-) transaction

Protecting Account Details

- ▶ Protecting during capture
- ▶ Verifying the account details with account provider (bank, PPI, etc. - new API may be needed from banks, or Re-1 transaction may be done to validate)
- ▶ PSPs storing the data should be always in encrypted form

Protecting Authentication Credentials

- ▶ Authentication credentials encrypted during capture using the public key of the authentication provider
 - ▶ "Trusted" common library for credential (MPIN/Password/PIN/Biometrics) capture. This library needs to bind customer mobile using HOTP/TOTP which is verified as part of transaction
- 
- A decorative graphic consisting of several concentric circles in shades of blue and purple, located in the bottom right corner of the slide.

Protecting against Phishing

- ▶ 3 core techniques may be used to protect against phishing:
- ▶ **Individual (nonentities)** pay/collect transactions can be against pre-created and verified address (quite like in the case of NEFT).
 - ▶ Allow direct/collect against ONLY whitelisted within the payer's pre-listed entries. Payer must add the payee explicitly into this list (quite like NEFT settings). During this, address verification can be done.
- ▶ **For individuals**
- ▶ PSP application should mandatorily share Aadhaar number and verified name which is part of customer information block which can be shown by the second PSP to their customer
- ▶ **For entities**
- ▶ PSP application should mandatorily share PAN number and verified name which is part of customer information block which can be shown by the second PSP to their customer
 - ▶ Whitelist entities (popular ones) and blacklist/rating at central database (NPCI) and show “verified symbol”

Message Security and Trust

- ▶ Every messages within the unified system must be digitally signed
- ▶ Every message has unique transaction ID (that spans across the organizations for same transaction) and unique message ID for every request-response pair
- ▶ All APIs must be done over a secure channel (HTTPS)
- ▶ Auditing transaction (no sensitive data) data for appropriate number of years

